Module 4 Learner Guide: Endpoint Security and Safe Digital Workflows

Start here

This afternoon you secure the devices and habits at every desk, then audit the controls of the fictional RSSO Assistance Portal on your own, using its records. The audit is worth 20% of your grade.

Item	Detail
Module	4 of 5: Endpoint Security and Safe Digital Workflows
Dates	Face-to-face: Thursday 22 October 2026. Online: Tuesday 27 October 2026
Time	4 hours, 1:00 to 5:00 PM (Day 2 afternoon)
Syllabus items	4.1, 4.2, 4.3 and the audit
Graded	Individual controls audit: findings register and access-control review, 20%
Bring	A laptop with a current browser (face-to-face), and your team's Module 3 role matrix

What you will be able to do

Level	By 5:00 PM you will be able to	Where you practise
Remember	Recall the Module 4 memory phrases and the four TLP labels	Check yourself; desk card
Understand	Explain why a padlock does not make a website honest, and why shadow IT is a data risk	Lesson 4.2
Apply	Check your own work device against a ten-point baseline	Self-check 4.1
Analyze	Tell safe from suspicious websites and tools, and find control gaps in a system's records	Try it 4.2; audit Part A
Evaluate	Rate each finding's severity and decide what to fix first	Audit Part A
Create	A corrected access-control table, and one 30-day action for your office	Audit Part B; Lesson 4.3

The afternoon

Time	Segment
1:00 to 1:15	Recall, the audit explained, audit rules acknowledged
1:15 to 1:50	4.1 Laptops, phones and remote work
1:50 to 2:20	4.2 Unsafe websites and shadow IT
2:20 to 2:30	Break
2:30 to 2:50	4.3 Threat intelligence and departmental awareness
2:50 to 3:00	Audit briefing and a walk through the audit file
3:00 to 4:00	Controls audit: Part A findings (about 40 minutes), Part B access control (about 20)
4:00 to 4:10	Break
4:10 to 4:30	Write-up and submission
4:30 to 4:50	Debrief: the main findings and the top five fixes
4:50 to 5:00	Day 2 close and Day 3 preview

Audit rules

Key idea: an audit compares what a system *should* do with what its records show it *does*, and writes down the gaps with evidence. You do it on paper, from the audit file; nothing is tested live.

Before the audit starts, everyone reads and acknowledges these rules: signed on paper face-to-face, ticked in the submission form online.

1. Work only from the Module 4 audit file. Everything in it is fictional.
2. Do not scan, probe or sign in to any real system, including your own office's. Accessing a computer system without right is illegal access under the Cybercrime Prevention Act (RA 10175, Section 4(a)(1)), so scope is a legal line, not a courtesy.
3. Never add real names, accounts or data to your findings.
4. Work on your own. You may ask the facilitator about the rules or the records, not for answers.
5. Submit through the submission link by 4:30 PM.

The same habit protects your office: only people with written authority test a system, and only within the scope they were given.

Lesson 4.1: Laptops, phones and remote work

Key idea: every device that touches office data is a door. Keep each one **updated, protected, encrypted and locked**.

The endpoint baseline

Control	Plain meaning	At the RSSO
Updates	Security updates installed promptly, automatically where possible	Ben's laptop updates overnight
Endpoint protection	Antivirus or endpoint protection running and current	Licences renewed before they lapse
Full-disk encryption	A lost device does not mean lost data	Sol's field laptop is encrypted
Screen lock	Locks after a few idle minutes; a PIN or password reopens it	Lock it whenever you stand up
Standard user account	Daily work without administrator rights	Only IT installs software
Host firewall	The device's own firewall is on	It matters most on public Wi-Fi
Removable media control	Only approved, encrypted USB drives	Unknown USB drives are blocked
Secure configuration	Unused features and accounts are turned off	IT's baseline for every new laptop

ISO/IEC 27001:2022 covers these in Annex A controls 8.1 (user endpoint devices), 8.7 (protection against malware), 7.9 (security of assets off-premises) and 6.7 (remote working).

Phones and tablets

- Install updates, remove apps you do not need, and check app permissions such as location, contacts and camera.
- Device management (MDM) lets IT enforce a screen lock and wipe a lost device; app management (MAM) protects only the work apps on a personal phone.
- Never root or jailbreak a device used for work: it removes the phone's own protections.
- Report a lost or stolen device at once, so IT can lock or wipe it.
- NPC Circular 2023-06 allows only known devices, properly configured to the office's security standards, to access personal data, and its rules cover remote disconnection or deletion on mobile devices.

Office devices or personal ones?

Question	Office-issued	Personal, where allowed
Who controls it?	The office	The owner
What must be in place?	The full baseline	A written policy, an approved-apps list and a separate work profile

Question	Office-issued	Personal, where allowed
Lost or stolen?	IT locks and wipes it	IT wipes the work profile only

Working from home and in the field

- Use the VPN for office systems.
- Home router: change its default admin password and install its updates.
- Public Wi-Fi: no office systems without the VPN; a phone hotspot is safer.
- Screen privacy: sit where others cannot read your screen, and lock it when you step away.
- Approved tools only: no personal email or messaging apps for official files.
- Printing and clean desk: print only what you need, collect it at once, and lock papers away.

When a device is lost

A lost, unencrypted laptop holding sensitive personal information can be a notifiable breach under the 3S test from Module 1: sensitive data, reason to believe an unauthorized person has it, and a real risk of serious harm (NPC Circular 16-03, Section 11). Report a lost device at once, because the 72-hour clock may already be running. Encryption is what turns "we lost the data" into "we lost a device".

At your desk, in the server room

At your desk	In the server room
Install updates when asked, and lock your screen	Automatic updates; endpoint protection renewed on time
Use approved, encrypted storage and USB drives	Full-disk encryption; device management with remote wipe
Report a lost device at once	Standard user accounts; a written policy for personal devices

Self-check 4.1: your device in three minutes (Apply, individual, not collected)

Tick each one that is true for the device you use for work.

- ☐ Security updates installed in the last month
- ☐ The screen locks by itself after a few idle minutes
- ☐ Full-disk encryption is on
- ☐ Antivirus or endpoint protection is running and current
- ☐ You work as a standard user, not as an administrator
- ☐ MFA is on for your office email
- ☐ No work files sit in personal cloud drives or messaging apps
- ☐ You know whom to call if the device is lost
- ☐ Your work files are backed up to approved storage
- ☐ At home, your router's default password has been changed

Each unticked box is a candidate for your 30-day action in Lesson 4.3.

Check yourself 4.1

1. Name four parts of the endpoint baseline.
2. Why should daily work happen on a standard user account?
3. What does NPC Circular 2023-06 say about devices that access personal data?
4. A field laptop with unencrypted applicant records is stolen. Why report it at once?

Lesson 4.2: Safe websites and approved tools

Key idea: the **padlock means private, not honest**, and office work uses **approved tools only**.

What the padlock tells you

The padlock (HTTPS) proves	It does not prove
The connection between your browser and that address is encrypted	Who runs the site, or that they are honest
The site holds a certificate issued for that address	That the address is the one you meant to visit

Criminals can get a certificate for an address they control. In June 2019 the FBI's Internet Crime Complaint Center warned that HTTPS and the padlock do not prove a site is legitimate, and that phishing sites were using them to look safe (Infosecurity Magazine).

Certificate warnings

A full-page warning such as "Your connection is not private" means the browser could not confirm the site's identity. Do not click past it and do not sign in. If it appears on an office system, tell IT: the usual cause is an expired or wrongly set-up certificate, which IT must fix rather than staff learning to ignore.

Look-alike addresses

The fictional RSSO Assistance Portal is at **assist.rsso-q.example**. Look-alikes copy it with small changes:

Trick	Example (fictional)
A swapped character	assist.rss0-q.example (a zero, not the letter o)
Extra words	rsso-q-payout.example
The real name at the front, the owner at the end	assist.rsso-q.example.verify-account.example

How to read an address: find the first single slash after https://, then read the words just before it from right to left. The last part names the owner. In the third example, the owner is verify-account.example, not the RSSO.

Addresses ending in .gov.ph are registered through DICT, which has maintained the .gov.ph domain since February 2020 under the Philippine Government Domain Names Policy (DOST-ASTI notice). Even so, the safest habit is to type an address you know, or use a bookmark, rather than follow a link in a

message. A password manager also helps: it offers your password only on the address where you saved it.

Downloads and pop-ups

- A page that says your browser is out of date and offers a download: close the tab. Updates come from the browser or the operating system itself, or from IT.
- A pop-up that says your computer is infected and gives a number to call: never call it. Close the browser and tell IT.
- An unexpected download: do not open it. Report it.

Shadow IT: the tool nobody approved

Shadow IT is any app, website, account or device used for office work without approval: a free file converter, a personal cloud drive, a personal messaging group, a browser extension, a public AI chatbot.

Why it matters even when nothing leaks:

- **The office stays responsible.** Under the Data Privacy Act, a personal information controller remains responsible for personal data it hands to another party for processing, and must use contracts or other reasonable means to keep it protected (RA 10173, Sections 14 and 21(a)). A free website has no agreement with the RSSO.
- **No controls and no record.** The office cannot see who opened the file, where it is stored, or whether it can be deleted.
- **No way back.** Once uploaded, the office cannot recall the data.

The approved-tools route

1. **Ask first:** is there an approved tool for this already?
2. **Request it:** if not, tell IT what you need to do and what data is involved.
3. **Check it:** IT checks security; the DPO checks privacy, with a privacy impact assessment where personal data is involved.
4. **Agree terms:** if the vendor will process personal data, a written agreement comes first.
5. **List it:** the tool goes on the approved list, with who may use it and for what data.

A fast route is itself a control: people take workarounds when the official way is slow.

What IT can add

- **Web filtering** blocks known malicious and look-alike sites (ISO/IEC 27001:2022 Annex A 8.23).
- **Data leakage prevention** warns or blocks when sensitive data leaves by email, upload or USB (8.12).
- **Supplier controls** put security duties into contracts and check cloud services before use (5.19 to 5.23).
- **Buying a new web system:** ask the vendor for proof that it was security-tested before go-live, for example against the OWASP Top 10, and who will fix problems found later.

At your desk, in the server room

At your desk	In the server room
Type known addresses or use bookmarks; never click past a certificate warning	Web filtering; certificates renewed before they expire
Use approved tools only; ask before you upload	An approved-tools list with a fast approval route
Report odd pop-ups and downloads	Data leakage prevention; security terms in every supplier contract

Try it 4.2A: Safe or suspicious? (Analyze, pairs, 8 minutes)

For each screen: is it safe or suspicious, which clue tells you, and what do you do?

1. Opening the office's leave portal, Dan sees a full-page warning: "Your connection is not private."
2. An SMS about a payout problem links to a sign-in page at assist.rss0-q.example. The page shows a padlock.
3. A colleague wants to merge two beneficiary masterlists using a free online PDF converter.
4. A news site shows a pop-up: "Your browser is out of date. Download the update now."
5. Ben opens assist.rsso-q.example from his own bookmark. The page shows a padlock.
6. In a messaging group, field staff post screenshots of applicants' IDs to ask a colleague to check them.

Try it 4.2B: Vet the tool (Evaluate, teams, 6 minutes)

Ask five questions before anyone uses a free online tool:

1. Who runs it?
2. Where does my input go?
3. What does a result mean, and can it be wrong?
4. Is it official, or approved by my office?
5. What must never go into it?

Your team takes one card:

Tool	Facts for the card
ScamCheck.ph	A free AI-assisted checker for suspicious messages, built by BetterGov.PH, a civic-tech group, and launched on 2 October 2025. It accepts pasted text, a screenshot or a forwarded email. The site warns that AI results can be wrong. It is not an official government tool.
Content Credentials Verify	Reads Content Credentials, signed information attached to a file that shows how it was made and edited. A file without credentials is not proven fake, and a screenshot does not carry the original's credentials.

Tool	Facts for the card
Pwned Passwords	Checks whether a password appears in known data breaches. Only the first 5 characters of the password's hash are sent, never the password itself (Troy Hunt).

Check yourself 4.2

1. What does the padlock prove, and what does it not prove?
2. A certificate warning appears on an office system. What do you do?
3. Why is uploading a masterlist to a free converter a privacy problem, even if nothing leaks?
4. Who checks a new tool before the office uses it with personal data?

Lesson 4.3: Threat intelligence and department awareness

Key idea: collect only what changes a decision, share it by its colour, and build habits that last.

What threat intelligence is

Threat intelligence is information about threats, collected and analysed so that an office can act on it. ISO/IEC 27001:2022 makes it a control (Annex A 5.7, Threat intelligence). The guidance for that control describes three layers (GRC Solutions; Aviso Consultancy):

Layer	What it tells you	Who uses it at the RSSO	Example
Strategic	The big picture: what kinds of attackers and attacks are rising	Director Eva, Carla	An advisory telling government offices to raise their guard
Tactical	Attackers' methods, tools and technologies	Ana, supervisors	Callers posing as DICT staff who threaten to cut off your SIM
Operational	Details of specific attacks, including technical signs	Ana	A list of sender addresses and links to block today

Good intelligence is **relevant, insightful, contextual and actionable**. Most of what reaches an inbox is none of these.

The test: does it change a decision this week?

Before you forward an item, ask whether it changes something you will do this week: an update to install, a warning to give staff, an account to check, a rule to change. If yes, act and tell the people who must act. If no, file it for the monthly bulletin or let it go. Forwarding everything trains people to ignore warnings.

Sharing safely: the Traffic Light Protocol

Shared security reports often carry a TLP label that says how far you may pass them on. TLP version 2.0 has applied since August 2022 (CERT-EU primer).

Label	Who may see it
TLP:RED	The named recipients only; no further sharing
TLP:AMBER	Your organization and its clients, on a need-to-know basis
TLP:AMBER+STRICT	Your organization only
TLP:GREEN	Your community, such as partner offices; not the public
TLP:CLEAR	Anyone; no limits

Remember **RED, AMBER, GREEN, CLEAR**: from tightest to open. When in doubt, ask the sender before sharing further.

Where to plug in

Source	What it gives you	Who at the RSSO
The Philippines' National CERT, working with DICT	Advisories; it also monitors official government domains against Have I Been Pwned breach data and sends alerts when new breaches affect them (Troy Hunt)	Ana, as the office's contact
DICT and CICC advisories	Example: on 8 September 2026, DICT and the CICC told national agencies, GOCCs, LGUs and critical infrastructure to raise their vigilance and give their head a one-page readiness assessment within 24 hours (Newsbytes)	Director Eva, Ana
Hotline 1326 and the CICC's ScamSafe	Scam reporting and public warnings (PNA; Newsbytes)	Everyone; Sol shares warnings with applicants
Vendor security advisories	Updates for the products the office runs	Ana
CISA's Known Exploited Vulnerabilities catalog	Weaknesses that attackers are known to be using, which CISA urges organizations to fix first (CISA)	Ana
MITRE ATT&CK	Common names for attacker behaviour, from Module 2	Ana

One office cannot rely on the national team alone. In 2023, DICT Undersecretary Jeffrey Ian Dy said the National CERT could not handle every agency, and that agencies need their own cybersecurity teams (ABS-CBN). For a regional office, that starts with a named focal person who receives advisories and knows whom to tell.

Department awareness that lasts

ISO/IEC 27001:2022 Annex A 6.3 (Information security awareness, education and training) and NPC Circular 16-03, Section 6, both call for training. Habits last when they are short, frequent and local:

- **A one-page monthly bulletin:** one threat, one habit, one contact.
- **Onboarding:** a security and privacy briefing before anyone receives system access.
- **Focal persons:** one per unit, who passes warnings on and collects questions.
- **Easy reporting:** one email address or one number for anything suspicious, and thanks for every report.
- **Practice:** short phishing simulations, approved by management in advance, followed by teaching, never shaming.
- **Measure what matters:** the **report rate** (how many people report a suspicious message) should rise, and the click rate should fall.

Your 30-day action

Choose one action from your self-check in Lesson 4.1 or from this afternoon's audit. Write it as: what you will do, by when, and how you will know it is done. Example: "By 20 November, MFA is on for every account in our unit; I will check the list with Ana."

At your desk, in the server room

At your desk	In the server room
Ask "does it change a decision this week?" before forwarding	One focal person registered with the national team
Respect TLP labels; ask the sender when unsure	Advisories and the KEV catalog checked against what the office runs
Report anything suspicious through the one channel	Monthly bulletin, onboarding briefings, report-rate tracking

Try it 4.3: Triage the inbox (Evaluate, pairs, 5 minutes)

For each item, decide: does it change a decision this week? If yes, who acts? How far may you share it?

1. A vendor advisory says the RSSO's VPN product has a security update for a weakness listed in CISA's KEV catalog.
2. A news article on global ransomware trends this year.
3. An alert, marked TLP:AMBER, says two RSSO staff email addresses appear in a newly reported breach.
4. A partner office shares a list of mobile numbers used by scammers posing as the RSSO, marked TLP:GREEN.
5. A forwarded chain message, with no source, says "Delete this app now or your phone will be hacked."
6. A joint advisory asks government offices to give their head a readiness assessment within 24 hours.

Check yourself 4.3

1. Name the three layers of threat intelligence.
2. What single question decides whether to act on an item?
3. A report is marked TLP:AMBER. Who may you share it with?
4. Which awareness measure should go up over time?

Graded controls audit: the RSSO Assistance Portal (20%)

You are the RSSO's internal reviewer. Using only the **Module 4 Audit File**, a set of fictional records about the RSSO Assistance Portal, you find where its controls fall short, rate each finding, and correct who can do what. Nobody tests or signs in to any system: the evidence is all on paper.

Item	Detail
Time	2:50 briefing; 3:00 to 4:00 audit (Part A about 40 minutes, Part B about 20); 4:10 to 4:30 write-up and submission
Work	Individual. You may talk ideas through with the person beside you, but every word you submit is your own
You need	The Audit File (Exhibits A to G); your team's Module 3 role matrix; the 5 by 5 matrix from Module 2
Submit	One file per person through the submission link by 4:30 PM: your findings register and access review, typed in your copy of the Audit File or written on the printed pages and photographed. If connectivity fails, the grace period runs until 8:00 AM the next day

The seven exhibits

Exhibit	What it holds
A	System profile: what the portal does, what data it holds, who owns it
B	User accounts: every account, its roles, MFA and last sign-in
C	Roles and permissions: what each role can do today
D	Security settings and records: passwords, sessions, logs, updates, backups, privacy notice
E	Vendors and agreements: who receives the portal's data, and on what terms
F	Screens and reports: what each role sees
G	Change and activity log: who changed what, and when

How to work: evidence, control, fix

1. **Read Exhibit A first (5 minutes).** Know what is at stake before you judge anything.

2. **Part A, findings (about 35 minutes).** Go through Exhibits B to G and record **at least 8 findings**. For each one, write:
    - what is wrong, in one plain sentence;
    - the **evidence**: exhibit and row, for example "D4";
    - the **control** it fails: an ISO/IEC 27001:2022 Annex A control, NPC Circular 2023-06, or a section of the Data Privacy Act;
    - likelihood and impact from 1 to 5, the score, and its band (Low 1 to 4, Medium 5 to 9, High 10 to 16, Critical 20 to 25);
    - the **fix**, an owner from the RSSO cast, and a target date.
3. **Part B, access review (about 20 minutes).**
    - For every account in Exhibit B, decide: **keep**, **change role**, **disable**, or **require MFA**, and give a one-line reason. One account may need two decisions.
    - Correct the role table in Exhibit C so that it matches your Module 3 role matrix, and list each separation-of-duties conflict you removed.
4. **Write-up (4:10 to 4:30).** Rank your top three findings and write three sentences to Director Eva: what is most urgent, what it could cost the office, and what you ask her to approve.

If a record suggests that something harmful may already have happened, say so in your finding and name who must be told today. Spotting that is part of the audit.

Worked example (not from your file)

A sharing-settings screen for the RSSO's staff leave spreadsheet shows "Anyone with the link can view".

Field	Entry
Finding	The staff leave spreadsheet is open to anyone who has the link
Evidence	Sharing settings screen, row 3
Control	ISO/IEC 27001:2022 Annex A 5.15, Access control; NPC Circular 2023-06, access control policy
Likelihood and impact	3, possible: links get forwarded. 3, serious: names, mobile numbers and leave dates of 60 staff
Score and band	9, Medium
Fix	Share with named accounts only and turn off link sharing
Owner and date	Ana, with the HR officer, by 30 October

Findings register

#	Finding	Evidence	Control	L	I	Score and band	Fix	Owner	Date
1									
2									

#	Finding	Evidence	Control	L	I	Score and band	Fix	Owner	Date
3									
4									
5									
6									
7									
8									

The Audit File has room for more rows.

Controls you will likely cite

Reference	What it covers
ISO 5.3	Segregation of duties
ISO 5.15 to 5.18	Access control, identity management, authentication information, access rights
ISO 5.19 and 5.20	Supplier relationships, and security in supplier agreements
ISO 6.5	Responsibilities after termination or change of employment
ISO 8.2 and 8.5	Privileged access rights; secure authentication
ISO 8.7, 8.8	Protection against malware; management of technical vulnerabilities
ISO 8.11	Data masking
ISO 8.13	Information backup
ISO 8.15	Logging
ISO 8.24	Use of cryptography
ISO 8.32	Change management
NPC Circular 2023-06	Access control policy; known, properly configured devices; password policy; MFA for online access to sensitive personal information; security logs kept; encrypted removable media; business continuity with testing
RA 10173 Sec 11	Principles: data adequate and not excessive (d); kept only as long as necessary (e)
RA 10173 Secs 14, 21(a)	The office stays responsible for data processed by others, and

Reference	What it covers
	protects it by contract
RA 10173 Sec 16(b)	Data subjects told what is collected, why, by whom, and for how long, before processing

How it is scored (100 points, scaled to 20%)

Criterion	Points	Full marks means
Findings	40	At least 8 valid findings, each with exhibit-and-row evidence; nothing invented
Analysis	25	Correct control references; likelihood and impact rated consistently and justified; top three ranked sensibly
Access-control management	20	A sound decision and reason for every account; a corrected role table with the conflicts removed
Remediation and clarity	15	Specific fixes, each with an owner and a date; a clear three-sentence summary for the head

Desk card: Module 4 additions

Add these to your desk card from Modules 1 to 3.

Phrase	What it means	What you do
Update, protect, encrypt, lock	The endpoint baseline	Install updates, keep protection on, encrypt the disk, lock the screen
Padlock means private, not honest	HTTPS encrypts the connection; it does not vouch for the site	Read the owner part of the address; type addresses you know
Approved tools only	Shadow IT puts office data where nobody controls it	Ask IT and the DPO before you use a new tool
Does it change a decision?	The test for threat intelligence	Act, and tell those who must act; otherwise file it
RED, AMBER, GREEN, CLEAR	How far a TLP-labelled report may travel	Share only as far as the label allows
Evidence, control, fix	How to write an audit finding	Exhibit and row; the control it fails; a fix with an owner and a date

Glossary

Term	Plain meaning
Access review	A regular check that every account still needs the access it has
Certificate (website)	A file that ties a web address to an encryption key, so the browser can set up HTTPS
Certificate warning	A browser page saying it cannot confirm the site's identity
Change management	Approving, recording and testing a change before it is made
Data leakage prevention (DLP)	Tools that warn or block when sensitive data leaves by email, upload or USB
Data masking	Hiding part of a value, such as showing only the last four digits of an ID number
Dormant account	An account nobody has used for a long time
Endpoint	Any device that connects to office systems: laptop, desktop, phone or tablet
Endpoint protection	Software that detects and blocks malware on a device
Full-disk encryption	Encryption of everything stored on a device, so a lost device does not expose its data
Generic or shared account	One login used by several people, so no one is accountable for what it does
KEV catalog	CISA's list of weaknesses that attackers are known to be using
Look-alike address	A web address made to resemble a real one
MDM and MAM	Mobile device management controls a whole device; mobile app management protects only the work apps
Privileged account	An account that can change settings or other people's access
Report rate	The share of staff who report a suspicious message
Segregation of duties	Splitting a task so that no one person can complete a risky action alone
Shadow IT	Apps, sites, accounts or devices used for office work without approval

Term	Plain meaning
Standard user account	A daily account without administrator rights
Threat intelligence	Information about threats, analysed so that an office can act on it
TLP	Traffic Light Protocol: labels that say how far a report may be shared
Web filtering	Blocking known malicious or unwanted websites

Answers

Check yourself 4.1

1. Any four of: updates, endpoint protection, full-disk encryption, screen lock, standard user account, host firewall, removable media control, secure configuration.
2. Anything that runs while you work, including malware opened by mistake, gets only your limited rights, so it can do less damage.
3. Only known devices, properly configured to the office's security standards, may access personal data. The circular also covers remote disconnection or deletion for mobile devices.
4. It may be a notifiable breach under the 3S test: sensitive data, reason to believe an unauthorized person has it, and a real risk of serious harm. The 72-hour clock runs from knowledge or reasonable belief of the breach, and IT may still be able to lock or wipe the device.

Try it 4.2A: Safe or suspicious?

#	Verdict	Clue	What to do
1	Suspicious	The browser cannot confirm the site's identity	Do not click past it or sign in; tell IT, who will usually find an expired or wrongly set-up certificate
2	Suspicious	A zero in place of the letter o; it arrived by SMS link; the padlock proves nothing	Do not sign in; report the text. If you already entered a password, change it at once from the real address and tell IT
3	Suspicious	Sensitive personal data going to an outside service with no agreement	Stop; use an approved tool or ask IT. The office stays responsible for that data (RA 10173, Secs 14 and 21(a))
4	Suspicious	Updates do not arrive through pop-ups on other websites	Close the tab; update through the browser itself or ask IT
5	Safe	Typed from his own bookmark; the owner part is rsso-q.example	Carry on

#	Verdict	Clue	What to do
6	Suspicious	ID images of applicants in an unapproved messaging group	Stop posting; move checks into the portal or an approved tool; tell the DPO, who decides whether this is a breach

Try it 4.2B: Vet the tool (model answers)

Question	ScamCheck.ph	Content Credentials Verify	Pwned Passwords
Who runs it?	BetterGov.PH, a civic-tech group, not a government agency	The card does not say: find out from the site before office use	Have I Been Pwned
Where does my input go?	The text, screenshot or email you send goes to the service	Not stated on the card, so do not upload office files until you know	Only the first 5 characters of the password's hash
Can a result be wrong?	Yes: the site warns that AI results can be wrong	A file without credentials is not proven fake; a screenshot carries none	"Found" means never use it; "not found" does not mean strong
Official or approved?	Not official; personal awareness only, unless your office approves it	Only after the approved-tools route	Only as your office's password policy allows
Never put in	Applicants' names, ID numbers or case details: remove them first	Images of applicants or their documents	Anyone else's password

Try it 4.3: Triage the inbox

#	Changes a decision this week?	Who acts	How far to share
1	Yes: attackers are already using this weakness, so update now	Ana; Director Eva approves any downtime	A public advisory: share freely
2	No: big-picture reading	Director Eva, in the monthly bulletin	Public: share freely
3	Yes: reset both passwords and check MFA and sign-in history	Ana, with the two staff	AMBER: within the office, on a need-to-know basis; not the all-staff chat
4	Yes: warn the staff who answer calls and texts	Sol and the frontline staff	GREEN: staff and partner offices, not the public. To warn citizens, ask the sender's permission or write

#	Changes a decision this week?	Who acts	How far to share
			your own warning without the list
5	No: no source, nothing to verify	Nobody; do not forward it	Do not pass it on; ask IT if unsure
6	Yes: there is a 24-hour deadline	Ana prepares; Director Eva receives and decides	As the advisory itself allows

Check yourself 4.2

1. It proves the connection is encrypted and the certificate was issued for that address. It does not prove who runs the site, that they are honest, or that it is the address you meant.
2. Do not click past it or sign in; tell IT.
3. The office stays responsible for personal data it hands to others and must protect it by contract (RA 10173, Secs 14 and 21(a)). A free site has no agreement, and the data cannot be recalled.
4. IT checks security and the DPO checks privacy, with a privacy impact assessment where personal data is involved; a written agreement comes first if the vendor will process personal data.

Check yourself 4.3

1. Strategic, tactical and operational.
2. Does it change a decision this week?
3. People in your organization, and its clients, who need to know.
4. The report rate.

Sources

All sources were opened and checked on 20 October 2026. Every person, office, address and record in the scenario is fictional.

- Data Privacy Act of 2012 (RA 10173), Secs 11, 14, 16 and 21: BATASnatin
- Cybercrime Prevention Act (RA 10175), Sec 4(a)(1), illegal access: BATASnatin
- NPC Circular 16-03, Personal Data Breach Management, Secs 6, 11 and 17: NPC
- NPC Circular 2023-06 requirements: Baker McKenzie summary, 19 April 2024; NPC FAQ; NPC announcement
- ISO/IEC 27001:2022 Annex A control names: Open Security Architecture
- Threat intelligence layers and qualities (ISO/IEC 27002 control 5.7): GRC Solutions; Aviso Consultancy
- FBI warning on HTTPS and the padlock, June 2019: Infosecurity Magazine
- DICT and the .gov.ph domain from February 2020: DOST-ASTI
- OWASP Top 10:2025: OWASP
- TLP 2.0: CERT-EU primer
- National CERT and Have I Been Pwned: Troy Hunt
- Agencies need their own cybersecurity teams: ABS-CBN, 8 October 2023

- DICT and CICC joint advisory, September 2026: Newsbytes
- Hotline 1326: PNA; ScamSafe: Newsbytes
- Known Exploited Vulnerabilities catalog: CISA
- ScamCheck.ph: World Ngayon; ScamCheck.ph
- Content Credentials and Verify: Content Authenticity Initiative FAQ; Verify documentation
- Pwned Passwords and k-anonymity: Troy Hunt
- MITRE ATT&CK, October 2025 update: MITRE